



Executive summary

AI AGENT + MCP + SKILL SECURITY REVIEW

Scope: Selected source directory; paths below are relative | Invarune 0.15.0

Incomplete scan - close the coverage gaps

The selected static scope was not fully inspected. There are 0 open findings, including 0 critical/high findings. Resolve reported gaps and review existing evidence before relying on this result.

0

OPEN FINDINGS

1

COVERAGE GAPS

9

FILES EXAMINED

Observed counts only. This is not an accuracy score or a security grade.

Deterministic layer: Incomplete selected scope.

Optional model review: finding stage completed; control stage completed. 0 model answers from 0 selected findings; 0 open findings outside the cap. 0 acceptance checks remain unanswered. Advisory control outcomes: 1 potential gaps; 1 checks need runtime, human or additional evidence. 1 additional advisory concerns require verification. Requested work is incomplete. Inspect the recorded errors; no model judgment resolves the static findings.

No open finding groups. Review accepted exceptions, coverage limits and active controls before drawing a deployment conclusion.

[Record a review decision and rescan](#)

Justified and disabled are human decisions, not passes. The full review forms and all evidence remain in this report.

Scan ID: 89791e8051d89f532704d66d4d26a1d4df049468a99252699448d9f86779e000



Contents

Executive summary	1
Contents	2
Priorities and first actions	3
Metrics and calculation	4
Observed findings and mitigating layers	5
Optional advisory review and evidence	6
Coverage gaps and required validation	10
Control checklist and evidence requirements	11
Scan configuration and scope	12
Deterministic checks and optional review	15
Coverage, misses and validation by area	16
Appendix / Deterministic rule inventory	23
Interactive review workspace	24



Priorities and first actions

Optional model review: finding stage completed; control stage completed. 0 model answers from 0 selected findings; 0 open findings outside the cap. 0 acceptance checks remain unanswered. Advisory control outcomes: 1 potential gaps; 1 checks need runtime, human or additional evidence. 1 additional advisory concerns require verification. Requested work is incomplete. Inspect the recorded errors; no model judgment resolves the static findings.

Severity counts describe observed open patterns. They do not establish exploitability or an estimated probability of compromise.

Critical		0
High		0
Medium		0
Low		0
Info		0

Severity counts use the existing scanner rules; no model or reviewer score is added.
Fix guidance: 0/0 findings have deterministic fix plans and agent/MCP context. Model fix plans: 0/0 finding assessments; 2/2 answered checks. Proposals require verification.
Review every detailed finding and gap below. Additional concerns can exist outside this bounded scan's supported syntax, files, budgets and execution context.



Metrics and calculation

No defensible universal security percentage can be calculated from static patterns or model opinions. Zero findings and 100% answered checks do not mean secure or compliant.

Measure	Result	Interpretation
Open deterministic findings	0 (0 critical/high)	Observed pattern counts. No severity weights or compromise probabilities are assigned.
Partial deterministic mapping reach	100.00% (1/1)	Active selected controls with an active selected mapped rule. Available partial coverage, not a pass rate.
Optional AI answer coverage	100.00% (2/2)	Active selected checks with a model answer, including concerns and unknowns. Review completion, not safety.

Selected scope: 4 rules (4 active); 1 controls (1 active); 2 active acceptance checks. 1 recorded coverage gaps.

Exact formulas

$100 \times \text{active selected controls with at least one active selected mapped rule} / \text{active selected controls}$. This describes partial rule availability, not completed tests, passes, or control effectiveness.

$100 \times \text{unique active selected acceptance checks with a received, valid model answer} / \text{active selected acceptance checks}$. An answer can be a concern or an explicit unknown. Disabled AI has zero answered checks; an empty denominator is not applicable (null), never 100%.

Advisory AI outcomes

Check outcome	Count
supported_by_code	0
potential_gap	1
needs_runtime_validation	0
needs_human_review	0
insufficient_evidence	1
not_applicable_proposed	0
not_reviewed	0

Supported by code and proposed non-applicability are advisory interpretations. Runtime/human validation and missing evidence remain unresolved. AI cannot erase findings, lower their severity, change the severity gate, or turn checks into passes.

Justified and disabled rules/checks are excluded from active metric denominators without pass credit. Findings with user decisions or baseline suppressions remain visible outside open-finding counts. Selection narrows the requested scope; it does not establish the excluded system is safe.

The existing CLI gate uses open deterministic findings at or above the configured severity. Scan/review/export errors can make requested work incomplete. Coverage percentages and model opinions never dismiss the gate.



Observed findings and mitigating layers

No selected static pattern was emitted. Review coverage gaps and control evidence before drawing a conclusion.



Optional advisory review and evidence

Model interpretations are advisory. They do not dismiss static findings, prove control effectiveness or change deterministic evidence. A verified quotation proves its presence in the supplied excerpt, not the correctness of the interpretation.

Omissions, evidence collection limits, errors and budgets are recorded in the optional-review summary above. Proposed verification steps have not been executed by this scanner.

Additional model concern - unverified

Review coverage is incomplete: `scan_complete_within_selected_scope` is false, `coverage_gaps` is 1, and source context is unavailable. No findings were supplied; this does not establish security. The gap details and scanned/excluded file inventory are needed to assess what remains unreviewed.

Model-proposed fix guidance (unverified)

Agent/MCP relevance: It is unknown whether the coverage gap affects agent tool execution, MCP authorization, or another trust boundary.

When this applies: Further review is warranted if the uncovered material implements or configures security-relevant behavior.

1. Obtain the coverage gap details and scanned/excluded file inventory. Identify any omitted MCP handlers, authorization checks, and tool execution paths; arrange appropriate review for those files. No code or configuration change is supported by the supplied evidence alone.

Verify: Check that each reported coverage gap has an explained disposition and that relevant agent/MCP entry points are included in the review scope. Treat any subsequent static scan as limited evidence, not runtime validation.

Bounded evidence investigation

Follow-up rounds: 2. Requests served / denied: 15 / 0. Captured files offered: 9. All requests share the configured call and evidence budgets; target tools and code are never executed.

EXEC-04:1 / file-efb8eb6d32ff5732dfea3c05:140-219 / risk_hypothesis / served

Reason: Trace path validation into filesystem access, including nonexistent targets, to assess whether attacker-controlled paths can escape between validation and use.

Counterevidence: Look for canonical target and parent checks, safe file handles, exclusive creation, and validation immediately associated with access.

EXEC-04:1 / file-efb8eb6d32ff5732dfea3c05:220-299 / risk_hypothesis / served

Reason: Inspect write and move operations for destination replacement, temporary-file handling, permissions, and separate validation of source and destination.

Counterevidence: Look for overwrite prevention, constrained temporary files, atomic operations, and protections against symlink substitution.

EXEC-04:1 / file-987db9b947eadc16acc4f7f9:7-86 / counterevidence / served

Reason: Determine how the containment predicate handles absolute paths, traversal, sibling prefixes, and platform separators.

Counterevidence: Look for component-aware containment and fail-closed handling of malformed or ambiguous paths.

EXEC-04:1 / file-5ae3d39aff74aeb01e9363af:195-274 / boundary_context / served

Reason: Inspect MCP registration and caller-side constraints connecting tool arguments to file access; the reported callback parsing gap remains unresolved.

Counterevidence: Look for schema restrictions, mandatory validation, safe access APIs, or evidence that the apparent operation is data-only.

EXEC-04:1 / file-5ae3d39aff74aeb01e9363af:350-429 / boundary_context / served

Reason: Inspect additional tool callbacks for direct filesystem operations and whether attacker-supplied paths consistently reach validation before access.

Counterevidence: Look for caller-side validation, restricted destinations, and wrappers that enforce containment independently of callback parsing.

EXEC-04:1 / file-5ae3d39aff74aeb01e9363af:725-786 / boundary_context / served

Reason: Determine whether client-provided roots replace or intersect the server's allowed directories and how updates affect the authorization boundary.

Counterevidence: Look for server-owned limits, authenticated root authority, and fail-closed handling of missing or invalid roots.

EXEC-04:1 / file-2f90dc06de04ee6c31f5153c:1-77 / counterevidence / served

Reason: Inspect root URI parsing and directory validation used to construct the filesystem access policy.

Counterevidence: Look for file-scheme restrictions, canonicalization, directory checks, and rejection of roots outside an independently established policy.

EXEC-04:2 / file-9b73cee629c530fd3bf63a92:1-43 / boundary_context / served

Reason: Identify declared test infrastructure and any supplied references to filesystem security tests; no test cases or execution results are currently provided.

Counterevidence: Look for explicit security-test coverage or test references while distinguishing test scripts from evidence that adversarial cases were exercised.

EXEC-04:1 / file-efb8eb6d32ff5732dfea3c05:77-139 / counterevidence / served



Reason: Inspect relative-path resolution and the Unicode fallback used when a requested target does not exist, particularly whether the returned target remains inside canonical allowed directories.

Counterevidence: Seek canonical parent containment checks, rejection of ambiguous targets, and protections against following an existing symlink through the fallback.

EXEC-04:1 / file-5ae3d39aff74aeb01e9363af:170-194 / boundary_context / served

Reason: Complete the visible text-read handler's argument-to-validation flow before its filesystem read; the supplied excerpt starts after validPath is established.

Counterevidence: Seek mandatory validation of the caller-controlled path and any file-handle-based access barrier. Reading this callback does not resolve the reported parser coverage gap.

EXEC-04:1 / file-5ae3d39aff74aeb01e9363af:275-349 / boundary_context / served

Reason: Trace media and multiple-file read callbacks to determine whether each supplied path is constrained before contents are returned to the MCP client.

Counterevidence: Seek per-target canonical validation, safe stream creation, and caller-side restrictions that could constrain the apparent read flow.

EXEC-04:1 / file-5ae3d39aff74aeb01e9363af:625-704 / boundary_context / served

Reason: Inspect remaining tool registrations for the caller of moveFile and related access operations, including whether both source and destination receive validation before mutation.

Counterevidence: Seek validation of both operands, restrictions on overwrites, and additional enforcement between validation and filesystem access.

EXEC-04:1 / file-efb8eb6d32ff5732dfea3c05:320-399 / risk_hypothesis / served

Reason: Follow the supplied editing function toward its eventual write and inspect adjacent read helpers for direct access after path validation.

Counterevidence: Seek reuse of guarded write operations, dry-run enforcement, exclusive temporary-file creation, or descriptor-based operations that limit symlink substitution.

EXEC-04:1 / file-9e181b70de0137f101e66dc0:1-25 / counterevidence / served

Reason: Inspect supplied deployment configuration for confinement that could limit the impact of client-selected roots or concurrent filesystem changes.

Counterevidence: Seek an explicit unprivileged identity, restricted filesystem exposure, or other concrete isolation settings; deployment declarations alone cannot establish runtime enforcement.

EXEC-04:2 / file-1e37847deefaaf829c40c17d:1-14 / boundary_context / served

Reason: Determine whether the supplied test configuration identifies relevant filesystem security tests or exclusions. The declared test script alone does not establish adversarial coverage.

Counterevidence: Seek explicit security-test inclusion or references to relevant fixtures, while retaining the absence of supplied test bodies and execution results as an evidence limitation.

EXEC-04 / Advisory check review: reviewed



Check 1 / potential_gap

Visible MCP handlers validate caller-supplied paths before filesystem operations, and `validatePath` checks both lexical containment and resolved symlink targets. However, validation returns a pathname that subsequent operations resolve again. Concurrent replacement of a path component could therefore undermine access-time containment. The move helper separately checks destination existence with `lstat` before `rename`, leaving an apparent overwrite race. Write and edit helpers use randomly named temporary files and atomic replacement, but temporary creation does not explicitly request exclusive creation or restrictive permissions; permission restoration occurs afterward and errors are ignored. These are unverified concerns whose impact depends on filesystem mutation rights, `umask`, and deployment isolation. Upload, download, and archive-specific behavior is not established by the excerpts.

Risk hypothesis: An attacker able to influence MCP path arguments and concurrently mutate directory entries could redirect a later pathname-based access after validation. Concurrent destination creation could defeat the move helper's intended no-overwrite behavior. Temporary replacement files may expose content more broadly than intended before permission restoration.

Trust boundary: MCP tool arguments enter `validatePath` and then reach filesystem reads or mutations under the server identity. The relevant enforcement boundary is the actual filesystem operation, including ancestor resolution, destination replacement, and temporary-file publication.

Counterevidence considered: Considered visible handler-side validation, separator-aware containment, `realpath` checks, Unicode ambiguity rejection and component checks, initial write creation with `'wx'`, random temporary names, atomic replacement, and destination `lstat`. These constrain static traversal and some symlink cases. Atomic replacement does not itself bind ancestor resolution or make the separate destination check atomic. Deployment isolation and attacker mutation rights remain unresolved.

Conclusion limits: No exploit or runtime behavior was verified. The callback parser coverage gap remains unresolved, and omitted handlers or caller constraints may change reachability. Effective identity, mounts, `umask`, root policy, and transfer or extraction support are not established. The assessment is advisory and subject to human review.

Model supplied this advisory interpretation.

Evidence `src-d28872b02bc6a10fe16c62ab / lib.ts:163-168`

```
Quoted excerpt: const realPath = await fs.realpath(absolute);
const normalizedReal = normalizePath(realPath);
if (!isPathWithinAllowedDirectories(normalizedReal, allowedDirectories)) {
  throw new Error('Access denied - symlink target outside allowed directories: ${realPath} not in ${allowedDirectories.join(', ')}');
}
return realPath;
```

Evidence `src-d0295ca728dc16eb8dc246c4 / lib.ts:247-251`

```
Quoted excerpt: await fs.lstat(destinationPath);
} catch (error) {
  if ((error as NodeJS.ErrnoException).code === 'ENOENT') {
    await fs.rename(sourcePath, destinationPath);
    return;
```

Evidence `src-3af1c30514bd02009e75c3c0 / lib.ts:341-344`

```
Quoted excerpt: const tempPath = `${filePath}.${randomBytes(16).toString('hex')}.tmp`;
try {
  await fs.writeFile(tempPath, modifiedContent, 'utf-8');
  await fs.rename(tempPath, filePath);
```

Verification still required: In an authorized isolated environment, test replacement of final and ancestor path components between validation and reads, writes, edits, and moves; verify that outside-root sentinel files remain unread and unchanged.

Verification still required: Test concurrent creation of a move destination after its existence check and establish whether the operation preserves the newly created destination.

Verification still required: Inspect temporary and replacement file permissions throughout writes and edits under deployed `umask` settings, including permission-restoration failures.

Verification still required: Review deployment mutation rights, filesystem mounts, root-update authorization and revocation behavior, and the complete operation inventory to establish upload, download, and extraction applicability.

Model-proposed fix guidance (unverified)

Agent/MCP relevance: Agent-controlled MCP path arguments cross into the server's filesystem authority. Concurrent filesystem writers introduce a second boundary: a pathname validated earlier may identify a different object when accessed. Client-provided roots also require an explicit ownership and authorization policy.

When this applies: Race-related changes are relevant where another process or principal can mutate accessible directory entries during an operation. Permission changes depend on the intended confidentiality policy and deployed `umask`. Archive-specific changes require evidence that extraction is supported.

1. Retain lexical and canonical containment checks. Where concurrent mutation is possible, use platform-supported descriptor-relative access with enforced beneath-root resolution, or deployment confinement that prevents access outside approved roots. A final-component no-follow flag alone does not protect ancestor components.
2. Replace the `lstat`-then-`rename` no-overwrite sequence with a platform-supported atomic no-replace operation or an equivalent filesystem-specific design whose guarantees cover every supported object type.
3. Create temporary files with `fs.open` using exclusive creation and mode `0o600`, write through the returned `FileHandle`, and apply intended permissions through that handle before publication. Define explicit handling for permission failures and separately protect parent-directory resolution.



4. Document who may change MCP roots and whether they must remain within an operator-defined ceiling; obtain complete handler and deployment evidence before proposing archive or transfer changes.

Verify: Retain regression results showing that final-component and ancestor substitution cannot redirect access beyond approved roots.

Verify: Verify that concurrent destination creation never causes an unintended move overwrite.

Verify: Verify temporary-file confidentiality, intended final permissions, and defined failure behavior on every supported deployment platform.

Check 2 / insufficient_evidence

The supplied configuration establishes Vitest test discovery and coverage settings, but no test bodies, fixtures, or execution results establish testing of symlink races, archive traversal, absolute paths, overwrite attempts, or secret-directory reads. Visible implementation guards are not evidence that these scenarios were tested. Missing test evidence does not establish that tests are absent; authorized runtime validation is required.

Risk hypothesis: Filesystem guards may behave differently under concurrent changes, platform-specific path semantics, or extraction behavior; ordinary functional tests may not exercise these conditions.

Trust boundary: The verification boundary runs from attacker-influenced MCP requests through filesystem operations to observable disclosure or mutation of synthetic protected fixtures.

Counterevidence considered: A Vitest test script and Node test configuration are supplied, so test infrastructure exists. Existing adversarial tests elsewhere are a plausible alternative, but no supplied test bodies or results establish their coverage. Production guards do not substitute for testing evidence.

Conclusion limits: Test completeness, execution outcomes, and archive applicability remain unknown. The static parser diagnostic also limits endpoint coverage. This advisory assessment does not infer that tests are missing and requires human review and authorized runtime evidence.

Model supplied this advisory interpretation.

Evidence src-c39da0c47ebf2e1715125cde / vitest.config.ts:5-6

Quoted excerpt: globals: true,
environment: 'node',

Evidence src-c7e718e049f51ab7a5cfbc94 / package.json:25-25

Quoted excerpt: "test": "vitest run --coverage"

Verification still required: Obtain relevant test bodies and recent results mapped to all five requested scenario categories, including supported platforms and filesystem assumptions.

Verification still required: Request deterministic race tests that coordinate mutation between validation and access, covering ancestor replacement and concurrent move-destination creation.

Verification still required: Review traversal and absolute-path cases, plus secret-directory read tests using synthetic sentinel content outside approved roots and through symlink aliases.

Verification still required: Establish whether archive extraction exists; if applicable, review tests for parent traversal, absolute entry names, link entries, and overwrite behavior.

Model-proposed fix guidance (unverified)

Agent/MCP relevance: Tests must exercise the MCP argument-to-filesystem boundary as well as helper functions, because agent-supplied paths, dynamic roots, and concurrent filesystem changes affect enforcement.

When this applies: First obtain existing security tests and execution evidence. Add coverage only where review identifies missing scenarios. Archive testing depends on confirmed extraction functionality.

1. Create a coverage matrix linking each requested scenario to existing test cases, expected outcomes, and recorded results.
2. Where coverage is missing, add isolated MCP integration tests with controlled synchronization for symlink substitution and destination-creation races.
3. Use synthetic restricted-directory fixtures to verify that rejected requests disclose no sentinel content and cause no outside-root changes.
4. Record the supported platform matrix and have an owner confirm archive applicability rather than inferring it from missing excerpts.

Verify: Have an owner review test assertions for unauthorized reads, writes, and overwrites, rather than relying only on returned errors.

Verify: Retain authorized runtime results with platform, filesystem, permissions, and umask context.

Verify: Confirm that each acceptance-check scenario has execution evidence or an explicitly reviewed applicability decision.



Coverage gaps and required validation

```
{"error": "MCP registerTool callback uses complex/default/rest parameters; tool entrypoint coverage is incomplete", "kind": "parse_error", "path": "index.ts"}
```



Control checklist and evidence requirements

EXEC-04 / Constrain file and archive access

Scanner status: no_pattern_detected | validation: hybrid

1. Resolve and enforce allowed paths at access time; constrain uploads, downloads, extraction, temporary files, and permissions.

Record review for EXEC-04:1

2. Test symlink races, archive traversal, absolute paths, overwrite attempts, and secret-directory reads.

Record review for EXEC-04:2

<https://modelcontextprotocol.io/specification/2026-07-28/client/roots>

<https://www.cyber.gov.au/business-government/secure-design/artificial-intelligence/deploying-ai-syste...>



Scan configuration and scope

Source scope and limits

Setting	Configured value
Default excluded directories	.cache, .git, .hg, .mypy_cache, .next, .pytest_cache, .svn, .tox, .venv, __pycache__, build, coverage, dist, node_modules, vendor, venv
Exclude	None
Explicit exclusion identity scope	Existing selected files and directories, including case aliases and file hardlinks; inputs must remain stable during the scan. Device/inode identities are not persisted in reports.
Explicit exclusion matching	resolved_paths_and_snapshot_filesystem_identities
Generated outputs and judge config excluded	Yes
Max entries	100000
Max file bytes	1000000
Max files	20000
Max total bytes	50000000
Requested scan ids	EXEC-04
Selected control ids	EXEC-04
Selected rule ids	AI015, AI016, AI037, AI047



Invocation and optional-review budgets

Setting	Configured value
Optional review / Analyst limits / Batch size	1
Optional review / Analyst limits / Investigation rounds	2
Optional review / Analyst limits / Max bytes	2000000
Optional review / Analyst limits / Max calls	3
Optional review / Analyst limits / Max chars	120000
Optional review / Analyst limits / Max files	200
Optional review / Analyst limits / Max seconds	900.0
Optional review / Cli login	never
Optional review / Cli timeout seconds	300.0
Optional review / Effective transport / Max request bytes	524288
Optional review / Effective transport / Max response bytes	1048576
Optional review / Effective transport / Model	gpt-6-astra
Optional review / Effective transport / Provider	codex_cli
Optional review / Effective transport / Timeout seconds	300.0
Optional review / Effective transport / Token optimizer	headroom
Optional review / Enabled	Yes
Optional review / Findings limit	100
Optional review / Include finding source	No
Optional review / Mode	full
Optional review / Provider	codex_cli
Optional review / Transport replay	Endpoints, credentials, headers, executable paths and identity stores are not embedded for automatic replay.
Reporting / Failure threshold	high
Reporting / Formats	html, markdown, json, sarif, pdf
Review inputs / Baseline	No



Setting	Configured value
Review inputs / Review config	No
Review inputs / Review report	No
Schema version	1.0

Image limits

Not present for this scan.

Source and image evidence are static. Image metadata, retained layers and packaged files do not reveal every runtime override or compiled program behavior.

Scanner provenance

Identity	Recorded value
Display name	Invarune by NimeshBuild
Implementation sha256	02c1a309226db622fe6ab86ae72b3c652e370d2faae3876b7ec64049d8f5e1c5
Name	agent-mcp-security-scan
Python version	3.12.14
Version	0.15.0



Deterministic checks and optional review

4 selected deterministic rules (4 active)

Deterministic checks inspect bounded Python syntax and local value flow, JavaScript/TypeScript lexical structure, structured JSON, configuration settings, selected secret patterns and image metadata. Repeated stable input produces repeatable evidence; it does not guarantee zero false positives or negatives.

Optional security analyst

If enabled, a model reviews selected findings and acceptance checks using bounded supplied evidence. Strict IDs, citations, response validation and tool restrictions constrain the protocol. Partial budgets, omitted answers and unavailable source/runtime evidence remain visible. Advice does not independently prove safety or erase static findings.

Review layer	Actual outcome / coverage
Finding review	completed; 0 selected; 0 outside cap
Control review	completed; 1/1 active controls answered
Unanswered acceptance checks	0/2 requested checks
Control requests	3/3 configured calls
Finding-stage error	None recorded
Control-stage errors	None

What can be missed

Cross-module/interprocedural flow, reflection, dynamic loaders, complex language syntax, templates before rendering, unsupported languages, compiled image behavior, runtime authentication/authorization, tenant isolation, egress policy, dependency CVEs and adaptive prompt injection require additional validation. A source declaration or proposed mitigation is not deployment evidence.

Human/runtime review workflow



1. Review evidence and the immediate concern. 2. Record a decision, reason, reviewer, date and evidence reference. 3. Validate runtime or human-dependent controls in the applicable environment. 4. Save and import the edited PDF or equivalent JSON. 5. Resolve rejected/stale edits, then rescan. Gaps remain operationally incomplete; blank decisions retain existing scanner semantics.



Coverage, misses and validation by area

Controls with rule mapping		1
Controls without rule mapping		0

Catalog mapping counts are not passed controls or percent secure.

Mapping counts describe available checks, not percent secure, detection accuracy or validated control effectiveness.

Execution and data flow

Deterministic: Python AST checks propagate selected registered-tool inputs and same-file arguments/returns, retain aliases and exact literal constraints, and check selected execution/file/network sinks. JavaScript tokens support narrow registerTool callbacks and direct-return named/arrow wrappers. Explicit world-writable chmod modes are checked.

Optional analyst: A model can form a trust-boundary hypothesis, request bounded captured source ranges to inspect callers or guards, seek counterevidence and explain what the supplied code still cannot establish.

Can miss or misclassify: Cross-file flows, unknown decorators/methods, complex JavaScript wrappers, dynamic imports, reflection, generated code and runtime values can hide a risk. Recognized resource/binding failures remain gaps. A dangerous API can be intentional and correctly constrained.

Validate elsewhere: Exercise actual entry points with authorized negative tests; verify input provenance, execution privileges and sandbox boundaries.

MCP identity, authorization and tools

Deterministic: Selected configuration/code signals flag insecure transport, explicit authentication bypass, token passthrough, broad tool grants and unpinned server launch packages.

Optional analyst: A model can review supplied authorization logic, tool descriptions and trust-boundary evidence for missing assumptions or inconsistent checks.

Can miss or misclassify: Configuration may differ from deployment. External gateways, identity providers, token audience checks and tenant boundaries may be absent from retrieved evidence.

Validate elsewhere: Test expired/wrong-audience tokens, cross-tenant access, per-tool authorization, consent binding and the deployed MCP transport.

Prompt injection, retrieval and memory

Deterministic: Selected patterns identify external content placed in privileged model messages and explicit approval/sandbox bypass. This is not an attack simulation.

Optional analyst: A model can reason about untrusted-content handling, persistent memory, tool-output influence and missing approval boundaries in the supplied excerpts.

Can miss or misclassify: Adaptive attacks, multi-turn interactions and tool chains depend on runtime behavior. Retrieval can omit the relevant code; a model can overlook an attack or be influenced by hostile evidence.

Validate elsewhere: Run isolated adversarial agent/MCP evaluations with attack-success and legitimate-task measurements, plus human review of consequential actions.

Secrets and data handling

Deterministic: Selected literal credentials, plausible private-key material, credential-bearing URLs, logging patterns and browser credential exposure are flagged and redacted best-effort.

Optional analyst: A model can identify sensitive data flows and retention concerns when the supplied evidence explains their context.

Can miss or misclassify: Encoded, split or runtime-fetched credentials can be missed; labels/test values can resemble secrets. Neither layer establishes whether a credential is live or redaction is complete.

Validate elsewhere: Verify secret stores, credential rotation, logging/retention policy, egress destinations and actual data-access permissions.

Skills and malicious-tool indicators

Deterministic: Bounded skill/tool/schema descriptions are checked for instruction hijacking, sensitive-data transfer, covert or approval-bypassing actions. Selected Spanish/French/German overrides and paired authority claims supplement English predicates. Python read-only tool annotations are compared with recognized direct write witnesses.

Optional analyst: A model can review intent, indirect social engineering, skill reference context and tool behavior visible in retrieved evidence, including cases where syntax or supported patterns are inconclusive.

Can miss or misclassify: A pattern is risk evidence, not proof of malicious authorship. Obfuscation, remote references, external packages, omitted context and runtime behavior can evade either layer.

Validate elsewhere: Inspect publisher provenance and the exact installed skill/tool; test consequential actions in an authorized isolated environment and verify effective permissions.



Built images and supply chain

Deterministic: Image archives are reconstructed without starting containers; supported packaged source, metadata, retained credentials, stored permissions and package inventories are inspected.

Optional analyst: A model can interpret supplied image/source evidence, flag missing deployment context and propose verification work.

Can miss or misclassify: Compiled logic, live deployment overrides, signature trust and dependency CVEs are not assessed. Package inventory and archive consistency do not establish safety or publisher identity.

Validate elsewhere: Use vulnerability/advisory analysis, provenance/signature verification and deployment testing alongside the static image assessment.

Operations and control effectiveness

Deterministic: The catalog retains governance, monitoring, recovery, approval and isolation checks even where no deterministic rule maps to them.

Optional analyst: Full review queues every active acceptance check and can identify evidence gaps or propose runtime/human validation; it can cite exact submitted source text.

Can miss or misclassify: A valid citation proves that a quote exists, not that the model's interpretation is correct. Policies, external services, incident procedures and production outcomes may be unavailable.

Validate elsewhere: Record owner-reviewed evidence, operational exercises and runtime results. A written justification remains an accepted exception, never an automatically validated pass.

Optional request payload optimization

Request	Requested / actual engine	Outcome	Evidence payload bytes
Finding request	headroom / headroom	optimized	1229 -> 1185 44 bytes saved
Control request 1	headroom / headroom	optimized	9025 -> 8689 336 bytes saved
Control request 2	headroom / headroom	optimized	39542 -> 38813 729 bytes saved
Control request 3	headroom / headroom	optimized	54595 -> 53779 816 bytes saved

These are measured evidence-JSON bytes, excluding instructions, response schemas and provider wrappers. Token and cost savings were not measured. Evidence-preserving formatting does not validate the model's interpretation.



Optional-review audit details

Recorded field	Recorded value
Analyst / Check status counts / Insufficient evidence	1
Analyst / Check status counts / Potential gap	1
Analyst / Coverage / Attempted controls	1
Analyst / Coverage / Batch size	1
Analyst / Coverage / Call budget	3
Analyst / Coverage / Calls made	3
Analyst / Coverage / Catalog checks	2
Analyst / Coverage / Catalog controls	1
Analyst / Coverage / Disabled checks	0
Analyst / Coverage / Disabled controls	0
Analyst / Coverage / Evidence / Budget exhausted	max_candidates_per_control
Analyst / Coverage / Evidence / Bytes charged	58024
Analyst / Coverage / Evidence / Bytes read	58024
Analyst / Coverage / Evidence / Candidate rankings dropped	59
Analyst / Coverage / Evidence / Candidate snippets	123
Analyst / Coverage / Evidence / Characters selected	1993
Analyst / Coverage / Evidence / Controls total	1
Analyst / Coverage / Evidence / Controls with evidence	1
Analyst / Coverage / Evidence / Controls without evidence	None
Analyst / Coverage / Evidence / Evidence files	3
Analyst / Coverage / Evidence / Failed read bytes charged	0
Analyst / Coverage / Evidence / File read attempts	9
Analyst / Coverage / Evidence / Files read	9
Analyst / Coverage / Evidence / Files verified	9



Recorded field	Recorded value
Analyst / Coverage / Evidence / Full repository review	No
Analyst / Coverage / Evidence / Limitations	Keyword-selected excerpts are partial context and do not prove implementation, absence, effectiveness, or compliance., Only unchanged manifest files are eligible; scanner exclusions and unsupported files remain outside this review., Credentials and environment files are excluded; other redaction is best-effort and source can contain sensitive data., Read budgets reserve one sentinel byte and conservatively charge failed read attempts, even if failure happened before any source bytes were read., No target code is executed, imported, installed, or contacted; repository instructions cannot change retrieval., Runtime behavior and missing evidence require additional validation; an empty control mapping is not a pass.
Analyst / Coverage / Evidence / Limits / Max bytes	2000000
Analyst / Coverage / Evidence / Limits / Max candidates per control	64
Analyst / Coverage / Evidence / Limits / Max chars	60000
Analyst / Coverage / Evidence / Limits / Max chars per excerpt	2000
Analyst / Coverage / Evidence / Limits / Max excerpts per control	4
Analyst / Coverage / Evidence / Limits / Max file bytes	1000000
Analyst / Coverage / Evidence / Limits / Max files	200
Analyst / Coverage / Evidence / Limits / Max lines per excerpt	12
Analyst / Coverage / Evidence / Limits / Max snippets	240
Analyst / Coverage / Evidence / Manifest files	9
Analyst / Coverage / Evidence / Requested characters selected	34317
Analyst / Coverage / Evidence / Scope	bounded_excerpts_from_unchanged_scanner_manifest_files
Analyst / Coverage / Evidence / Selection method	deterministic_control_keywords_and_findings
Analyst / Coverage / Evidence / Skipped files	None
Analyst / Coverage / Evidence / Snippets selected	4
Analyst / Coverage / Excluded checks	0
Analyst / Coverage / Excluded controls	0
Analyst / Coverage / Justified checks	0
Analyst / Coverage / Justified controls	0



Recorded field	Recorded value
Analyst / Coverage / Omitted checks	0
Analyst / Coverage / Reviewed controls	1
Analyst / Coverage / Time budget seconds	900.0
Analyst / Coverage / Total checks	2
Analyst / Coverage / Total controls	1
Analyst / Coverage / Unreviewed control ids	None
Analyst / Coverage / Validated controls	0
Analyst / Enabled	Yes
Analyst / Errors	None
Analyst / Status	completed
Judge / Cli / Arguments	-a, never, exec, --ignore-user-config, --ignore-rules, --ephemeral, --skip-git-repo-check, --sandbox, read-only, --json, --color, never, --disable, shell_tool, --disable, unified_exec, --disable, code_mode, --disable, code_mode_host, --disable, computer_use, --disable, browser_use, --disable, browser_use_external, --disable, browser_use_full_cdp_access, --disable, in_app_browser, --disable, image_generation, --disable, view_image, --disable, artifact, --disable, apps, --disable, plugins, --disable, plugin_sharing, --disable, hooks, --disable, multi_agent, --disable, multi_agent_v2, --disable, skill_search, --disable, workspace_dependencies, --disable, shell_snapshot, --disable, memories, --disable, sleep_tool, --disable, goals, --disable, remote_plugin, --disable, tool_suggest, -c, web_search="disabled", -c, mcp_servers={}, -c, project_doc_max_bytes=0, -c, skills.include_instructions=false, -c, model_reasoning_effort="high", --output-schema, <private temporary directory>/response-schema.json, --model, gpt-6-astra, -
Judge / Cli / Auth mode	cli_managed
Judge / Cli / Cli version	0.154.0
Judge / Cli / Descendant termination	process_group
Judge / Cli / Executable	codex
Judge / Cli / Isolation	CLI capability restrictions; installed executable and administrator policy remain trusted
Judge / Cli / Provider	codex_cli
Judge / Cli / Repository working directory	No
Judge / Cli / Request bytes	3399
Judge / Cli / Request sha256	2bbb2d87b5d67911fd0c5453b7d806010b68391badd4d17d569e4d6da3d2df6e
Judge / Cli / Requested model	gpt-6-astra
Judge / Cli / Response bytes	1802



Recorded field	Recorded value
Judge / Cli / Response sha256	ebd52f9b0ba8b39db0344c526e4f59ab7a7606259c04c7fbc7064f91eabf07b6
Judge / Cli / Stage	findings
Judge / Cli / Startup warnings	codex_code_mode_intentionally_disabled
Judge / Cli / Structured output requested	Yes
Judge / Cli / Token budget enforced	No
Judge / Cli / Token optimization / Bytes saved	44
Judge / Cli / Token optimization / Engine	headroom
Judge / Cli / Token optimization / Evidence preserved	Yes
Judge / Cli / Token optimization / Fallback reason	Not configured
Judge / Cli / Token optimization / Headroom version	0.37.0
Judge / Cli / Token optimization / Original payload sha256	1b6e028b2d3bc22a4e9e0b8516fcd2b09f7f2bce5af979b1bf8a318a754c944c
Judge / Cli / Token optimization / Payload bytes after	1185
Judge / Cli / Token optimization / Payload bytes before	1229
Judge / Cli / Token optimization / Requested	headroom
Judge / Cli / Token optimization / Schema version	1.0
Judge / Cli / Token optimization / Scope	Evidence JSON only; excludes instructions, response schemas and provider wrappers
Judge / Cli / Token optimization / Sent payload sha256	8b04a9e5367f23d7de64889eb95859f2184ba39de6a019a724fa8eeb2018f3d5
Judge / Cli / Token optimization / Status	optimized
Judge / Cli / Token optimization / Token savings measured	No
Judge / Cli / Tools policy	disabled_for_advisory_review
Judge / Cli / Transport	official_cli
Judge / Enabled	Yes
Judge / Model	gpt-6-astra
Judge / Omitted open findings	0
Judge / Provider	codex_cli



Recorded field	Recorded value
Judge / Selected findings	0
Judge / Source context requested	No
Judge / Source context sent count	0
Judge / Source context skipped	None
Judge / Status	completed



Appendix / Deterministic rule inventory

Only selected rules appear here. User-justified and disabled selections remain recorded in the decision audit and do not earn pass credit.

AI015 / Externally influenced filesystem path

A filesystem operation consumes an obvious external-input expression. Review whether canonical path checks and symlink handling confine access to the intended workspace.

AI016 / Race-prone temporary filename creation

`tempfile.mktemp` returns an unused name without atomically creating the file, allowing a race with another local process.

AI037 / Archive extraction without an explicit safe filter

A tar extraction call has no explicit safe data filter, or selects a fully trusted filter. Behavior depends on the Python version and archive provenance.

AI047 / Filesystem permissions explicitly allow writes by everyone

A recognized Python `chmod` call sets the other-write permission bit. Shared agent workspaces, tool artifacts or credential files may be changed by another local identity. Actual access depends on platform permissions, ownership, ACLs and deployment isolation.



Interactive review workspace

Every bound item below remains tied to its original evidence. Blank means unreviewed. Any nonblank decision requires a reason; justified/disabled also require a reviewer. Coverage gaps cannot be justified or disabled. Runtime/human decisions identify outstanding validation and are not passes.

Long fields scroll in compatible PDF viewers. Save with regenerated appearances. If your editor flattens the form or cannot preserve it, use the JSON review workspace instead.

Acceptance check review

[Back to evidence](#)

EXEC-04:1 Resolve and enforce allowed paths at access time; constrain uploads, downloads, extraction, temporary files, and permissions.

Evidence binding: 0d48c32c4e3def92cc1083260ab889cb8b6f2513b008d1524023a02b0b293ef7

DECISION

Unreviewed

REVIEWER

REASON / JUSTIFICATION

REVIEWED AT (YOUR DATE)

EVIDENCE REFERENCE

Acceptance check review

[Back to evidence](#)

EXEC-04:2 Test symlink races, archive traversal, absolute paths, overwrite attempts, and secret-directory reads.

Evidence binding: 7d1f37123b0099018b87b13f7fe63762aef0f623c0c3ad41cbe2b89add1d7b35

DECISION

Unreviewed

REVIEWER

REASON / JUSTIFICATION

REVIEWED AT (YOUR DATE)

EVIDENCE REFERENCE



Coverage gap review

[Back to evidence](#)

index.ts: MCP registerTool callback uses complex/default/rest parameters; tool endpoint coverage is incomplete

Evidence binding: 7f1a8b8a00e928a207693ea26c4301f71e84d78787ba757dede7befc5013f574

DECISION

Unreviewed

REVIEWER

REASON / JUSTIFICATION

REVIEWED AT (YOUR DATE)

EVIDENCE REFERENCE